

SoK: Understanding the State of IoT-specific Vulnerabilities via CVE Characterization with LLIoT

Tina Rezaei

Suzan Bayhan

Andrea Continella

Jeroen van der Ham-de Vos

Roland van RijsWijk-Deij

Motivation

- IoT attacks usually use known vulnerabilities for exploitation.
 - A 2019 study (Feng et al., CCS): **96%** of attack scripts captured by IoT honeypots matched **publicly available vulnerability** reports.
- Known IoT vulnerabilities can inform improved or targeted mitigation.

Problem

- NVD is the most reach source of vulnerabilities since 1999, but no metadata about IoT.
- Hard to find IoT CVEs among hundreds of thousands of records.

What prior work has done

- IoT CVE distinction
 - Reliance on weak heuristics such as keyword filtering or metadata (e.g., CPE) followed by human review
 - high false positives & low coverage
 - limited scalability.
 - Underspecified IoT definitions.
- IoT taxonomy
 - Prior IoT taxonomies vary in granularity and perspective

What we do

LLIoT: An LLM-assisted approach to systematically distinguish IoT CVEs at large scale

Phase 1: Ground-truth & validation

- Define IoT taxonomy
- Create keyword dictionaries
- Filter CVEs
- Manual review
- Validate LLMs and human

Phase 2: Large scale classification

- Apply best-performing LLM
- Classify all 225k CVEs
- Consistency analysis
- Comparison with prior datasets
- Manual verification

Phase 3: Characterization

- Temporal trends
- Severity analysis
- Weakness families
- Actionable recommendations

IoT Taxonomy & Classification Rules

4-layer IoT taxonomy:

Device

Constrained hardware,
firmware, embedded OS

IP camera, thermostat,
FreeRTOS, smart lock

Typical flaws: firmware,
hardware, embedded OS bugs

Communication

Low-power protocols and their
stacks

ZigBee, BLE, 6LoWPAN,
LoRaWAN, MQTT, CoAP

Typical flaws: protocol design,
stack bugs

Application

Companion apps and
orchestration

Home Assistant,
SmartThings, IFTTT,
OpenHAB

Typical flaws: design and logic
flaws

Cloud backend

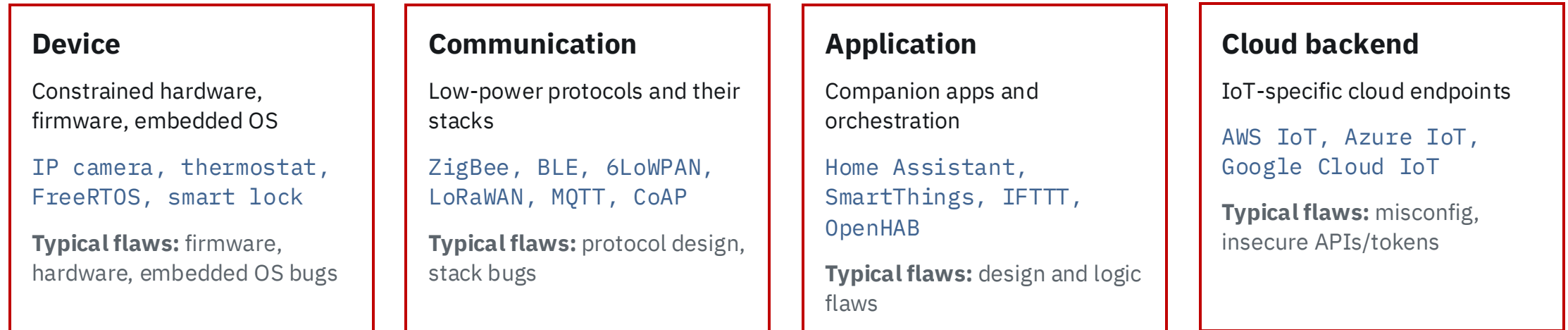
IoT-specific cloud endpoints

AWS IoT, Azure IoT,
Google Cloud IoT

Typical flaws: misconfig,
insecure APIs/tokens

IoT Taxonomy & Classification Rules

4-layer IoT taxonomy:



Classification rules:

- IoT-specific = technology purpose-built for IoT + deployed in IoT context + is an active element of an IoT system
- Non-IoT = Vulnerabilities not fit in IoT + smartphones/laptops/PCs + Network infrastructures (routers, modems)

Building the Ground-Truth Dataset

Ground-truth sample selection

- 4 IoT Keyword dictionaries (one per layer)
- 851 potential IoT CVEs filtered
- 150 potential IoT CVEs randomly samples
- 150 potential non-IoT CVEs randomly samples
- Total 300 CVEs for expert review

Ground-truth labeling

- 9 reviewers (Security professor, Security expert, PhDs in IoT & cybersecurity, Internet measurement, Quantum crypto for IoT, Web privacy)
- Divided in 3 groups of 3 reviewers
- 100 CVEs per group, each CVE reviewed by 3 people
- CVE label set by majority voting

Building the Ground-Truth Dataset

Affected
vendor &
product

Current CVE Index: 19 (Range: 0 to 99)

CVE-2021-31664

Description

Description: RIOT-OS 2021.01 before commit 44741ff99f7a71df45420635b238b9c22093647a contains a buffer overflow which could allow attackers to obtain sensitive information.

[View on NVD](#)

Vendor:Product:

- riot-os:riot

1) Is this CVE IoT-related?

IoT/Non-IoT label?

IoT specific

Not IoT

Not sure

2) Which component caused this vulnerability (if IoT)?

Layer-level label?

Device

Application

Communication

Cloud Backend

Not sure

Why do you think this is IoT-related or Non-IoT?

Reasoning?

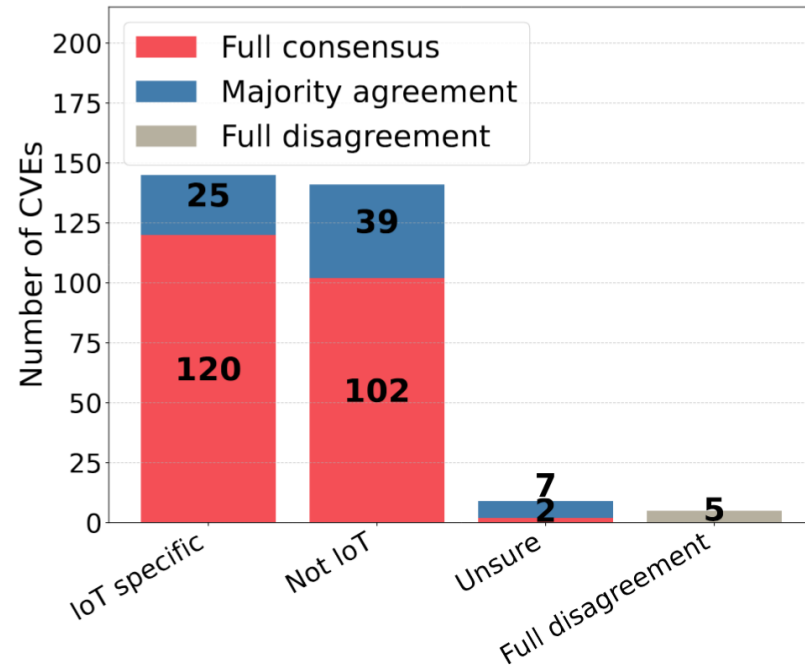
RIOT-OS is an OS for IoT devices. The vulnerability is related to buffer overflow which falls under device component.

← Previous

Submit & Next →

[Review Dashboard](#)

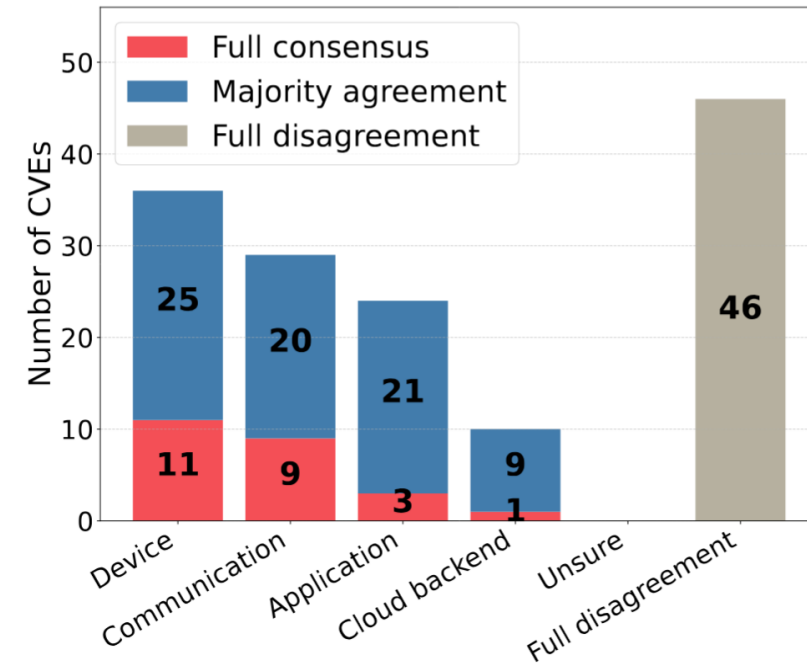
Manual labeling outcomes



IoT/Non-IoT Classification

Krippendorff $\alpha = 0.80$

Satisfactory agreement



Layer-level classification

Krippendorff $\alpha = 0.28$

Poor agreement

Tie breaker

148 IoT & 152 non-IoT

- CVE descriptions lack technical detail
- Reviewer expertise gaps
- Some vulnerabilities span multiple layers

LLM Performance on the Ground-Truth Dataset

Model	Accuracy	Precision	Recall	F1 score
O3	94.67	93.96	95.24	94.59
GPT-4O	95.33	94.04	96.60	95.30
DeepSeek-r1-70B	92.67	89.81	95.92	92.76
Llama4-scout	89.33	83.63	97.28	89.94

CVE-2016-6769

Description

An elevation of privilege vulnerability in Smart Lock could enable a local malicious user to access Smart Lock settings without a PIN. This issue is rated as Moderate because it first requires physical access to an unlocked device where Smart Lock was the last settings pane accessed by the user.

Affected Product (CPE)

cpe:2.3:o:google:android:5.0:*:*:*:*:*:*

LLM vs human reasoning

Human errors:

- Cognitive error -> "smart lock" misread as IoT device while Android feature (CVE-2016-6769)
- Limited domain-knowledge -> "modem" misunderstood as cable modem (CVE-2022-33211)
- Unsure labels for poorly documented technologies (CVE-2024-25507)

LLM errors:

- Borderline technologies (Busy box, WolfSSL)

LLM Performance on the Ground-Truth Dataset

Model	Accuracy	Precision	Recall	F1 score
O3	94.67	93.96	95.24	94.59
GPT-4O	95.33	94.04	96.60	95.30
DeepSeek-r1-70B	92.67	89.81	95.92	92.76
Llama4-scout	89.33	83.63	97.28	89.94

Model	Accuracy	Precision	Recall	F1 score
Human reviewers	97.58	98.6	97.24	97.92
O3	99.31	100	99.31	99.65
GPT-4O	97.58	97.28	98.62	97.95
DeepSeek-r1-70B	96.19	94.7	98.62	96.62
Llama4-scout	92.39	87.8	99.31	93.2

LLM vs human reasoning

Human errors:

- Cognitive error -> "smart lock" misread as IoT device while Android feature (CVE-2016-6769)
- Limited domain-knowledge -> "modem" misunderstood as cable modem (CVE-2022-33211)
- Unsure labels for poorly documented technologies (CVE-2024-25507)

LLM errors:

- Borderline technologies (Busy box, WolfSSL)

Phase 2: Large scale classification

Phase 1: Ground-truth & validation

- Define IoT taxonomy
- Create keyword dictionaries
- Filter CVEs
- Manual review
- Validate LLMs and human

Phase 2: Large scale classification

- Apply best-performing LLM
- Classify all 225k CVEs
- Consistency analysis
- Comparison with prior datasets
- Manual verification

Large Scale Classification & Consistency

- Applying O3 to all CVEs from 2013 to 2024 (225,262) ➔ 15,066 IoT CVEs

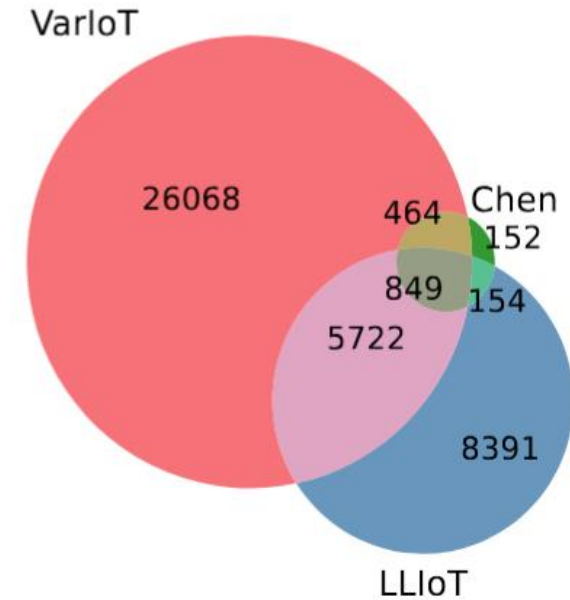
Consistency analysis

- 10 classification iterations on 1000 randomly selected CVEs (500 IoT & 500 Non-IoT)
- Unanimity (U): Measures how often the exact same label is assigned to a CVE across all runs
- Maximum class agreement(C): Measures consistency per CVE, the fraction of most frequent assigned label

	U	95% bootstrap CI	C	95% bootstrap CI	n
Overall	0.92	[0.90, 0.94]	0.98	[0.97, 0.98]	1000
IoT	0.86	[0.83, 0.88]	0.96	[0.95, 0.97]	500
Non-IoT	0.98	[0.97, 0.99]	0.99	[0.995, 0.999]	500

Dataset Comparison and Quality Validation

Dataset	# IoT CVEs	Methodology
VarIoT	33,103	Keyword filtering (multi-level)
Chen et al.	1,619	Keyword filtering + manual review
LLIoT	15,066	LLM assisted



Why is VarIoT so large?

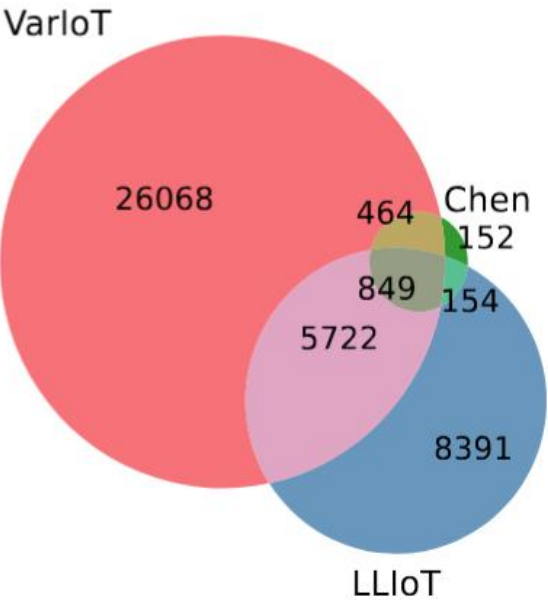
Method	Network	Industrial	Home&Office	Camera	Embedded	Vehicle	Wearable	Medical	Other	Total
VarIoT	9,070	3,057	121	103	97	32	16	5	20,592	33,103
LLIoT coverage	1358 (14.9%)	2,326 (76%)	120 (99.2%)	93 (90.2%)	68 (70.1%)	19 (59.4%)	7 (43.7%)	5 (100%)	2,575 (12.5%)	6,571 (19.8%)
Chen et al. [40]	350	36	191	275	92	36	14	7	618	1,619
LLIoT coverage	90 (25.7%)	33 (91.6%)	175 (91.6%)	238 (86.5%)	78 (84.8%)	23 (63.9%)	13 (92.9%)	7 (100%)	346 (55.9%)	1,003 (61.9%)

Janiszewski et al., "Automatic actionable information processing and trust management towards safer Internet of Things", Sensors, 2021

Chen et al., "An empirical study of high-risk vulnerabilities in IoT systems", IEEE Internet of Things Journal, 2024

Dataset Comparison and Quality Validation

Dataset	# IoT CVEs	Methodology
VarIoT	33,103	Keyword filtering (multi-level)
Chen et al.	1,619	Keyword filtering + manual review
LLIoT	15,066	LLM assisted



Why is VarIoT so large?

Method	Network	Industrial	Home&Office	Camera	Embedded	Vehicle	Wearable	Medical	Other	Total
VarIoT	9,070	3,057	121	103	97	32	16	5	20,592	33,103
LLIoT coverage	1358 (14.9%)	2,326 (76%)	120 (99.2%)	93 (90.2%)	68 (70.1%)	19 (59.4%)	7 (43.7%)	5 (100%)	2,575 (12.5%)	6,571 (19.8%)
Chen et al. [40]	350	36	191	275	92	36	14	7	618	1,619
LLIoT coverage	90 (25.7%)	33 (91.6%)	175 (91.6%)	238 (86.5%)	78 (84.8%)	23 (63.9%)	13 (92.9%)	7 (100%)	346 (55.9%)	1,003 (61.9%)

Janiszewski et al., "Automatic actionable information processing and trust management towards safer Internet of Things", Sensors, 2021
Chen et al., "An empirical study of high-risk vulnerabilities in IoT systems", IEEE Internet of Things Journal, 2024

Dataset Comparison and Quality Validation

- Manual verification of 100 samples per dataset

VarIoT

- 43 network devices
- 21 chipsets and OSes (iOS, macOS, tvOS)
- 36 Non-IoT (Google Chrome, WordPress plugins, Perl, Adobe Flash Player, Safari)

Keyword search: 671 Adobe Flash. 801 Safari. 62 WordPress

Chen et al.

- 13 network devices
- 59 chipsets and various Android and Linux drivers
- 28 Non-IoT (Windows, wired speakers, desktop and non-IoT web apps)

LLIoT

- 22 IoT consumer devices (cameras, infusion pump, smart lock, printer, drone, smartTV, wearable)
- 9 chipsets and 64 (EV charging station, building automations, industrial controller, IoT SDK, communication stack)
- 4 Non-IoT (PLC engineering software, robotics simulation software, and web management software)

Phase 3: IoT vs non-IoT characterization

Phase 1: Ground-truth & validation

- Define IoT taxonomy
- Create keyword dictionaries
- Filter CVEs
- Manual review
- Validate LLMs and human

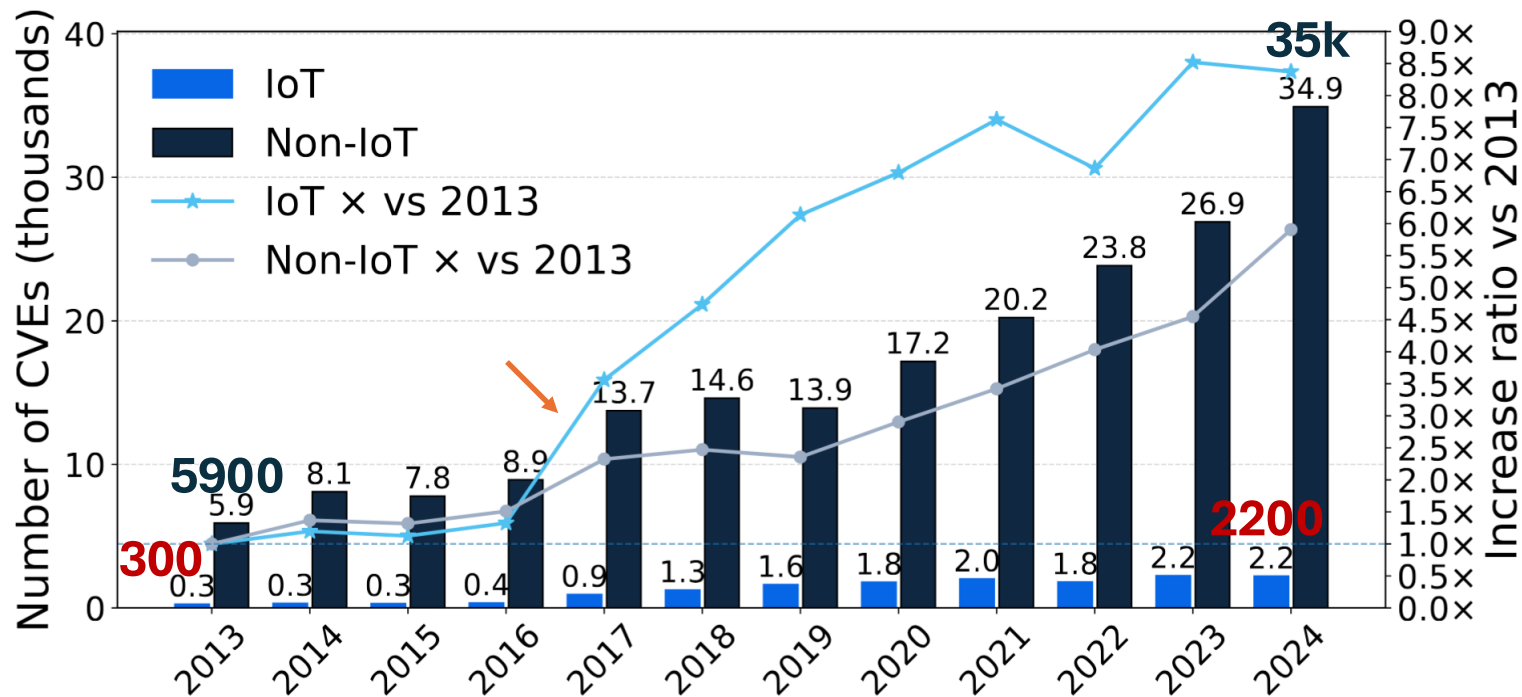
Phase 2: Large scale classification

- Apply best-performing LLM
- Classify all 225k CVEs
- Consistency analysis
- Comparison with prior datasets
- Manual verification

Phase 3: Characterization

- Temporal trends
- Severity analysis
- Weakness families
- Actionable recommendations

IoT CVE Temporal Trends

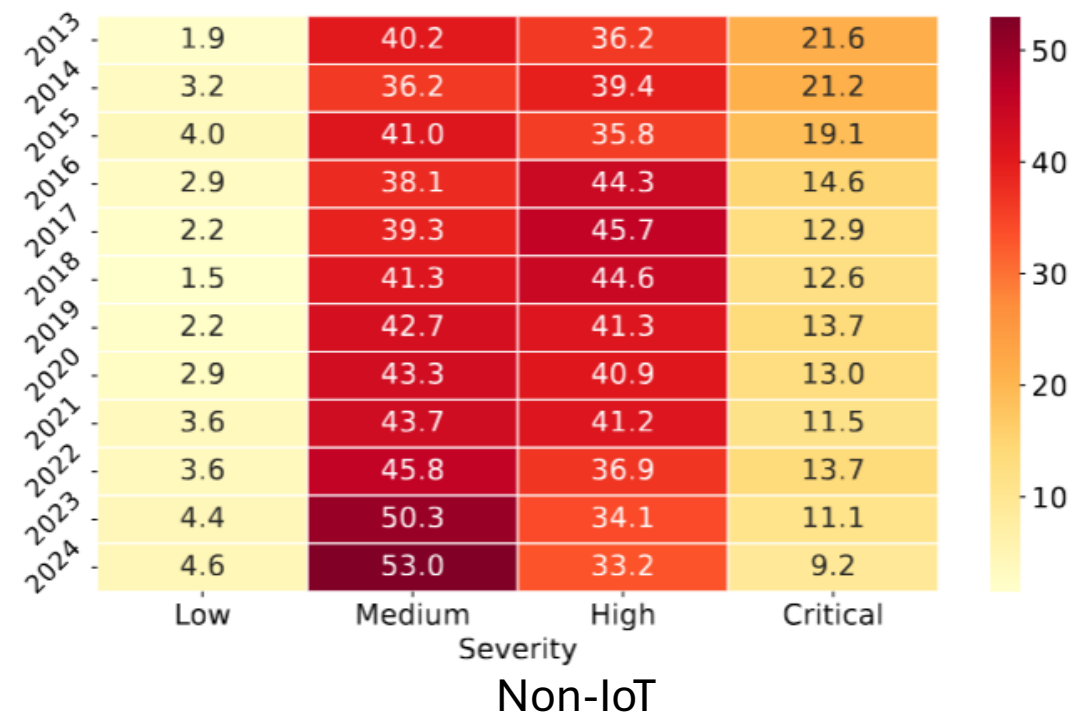
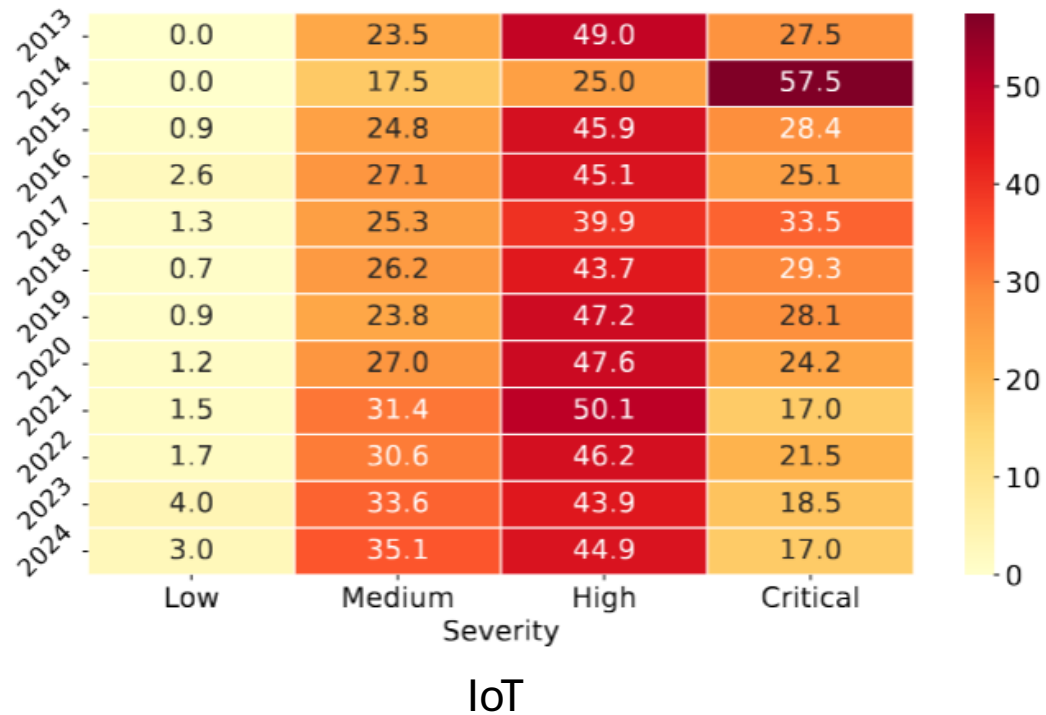


8.5× IoT growth vs 2013
6× Non-IoT growth vs 2013

Steep rise in IoT 2016 -> 2017

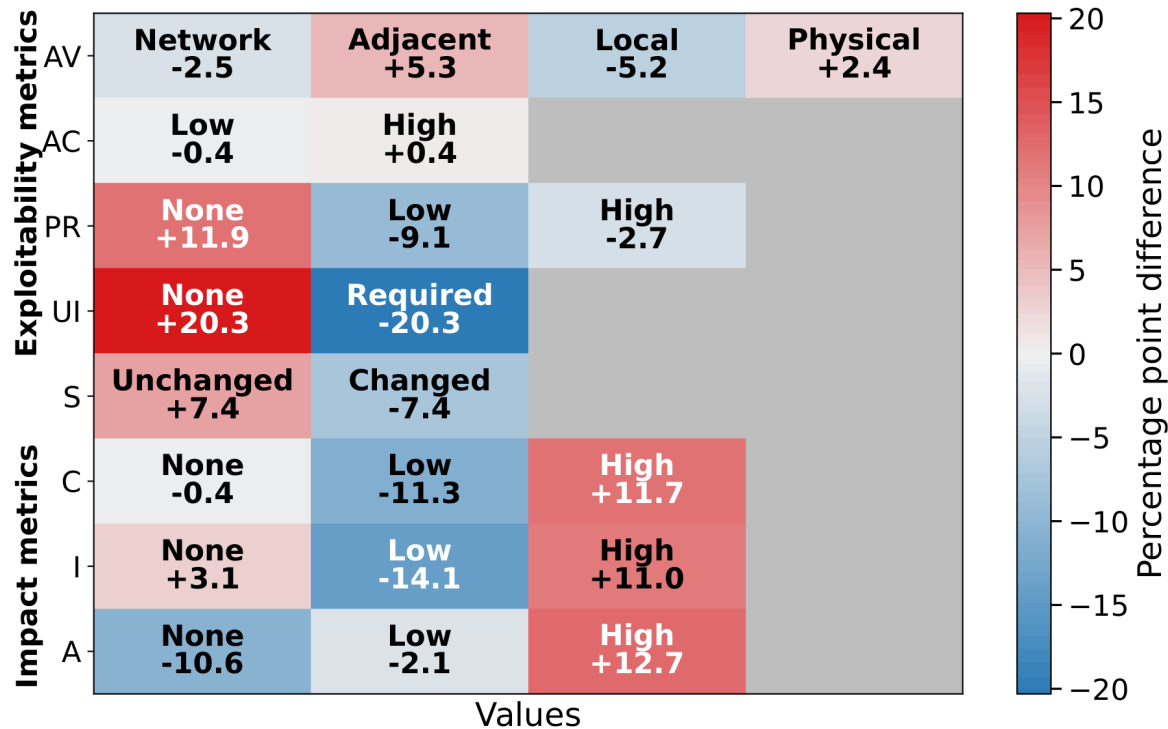
- Mirai botnet in 2016
- CNA program expansion in 2016

Severity Analysis



- IoT holding higher severity than Non-IoT
- Non-IoT shifting from high and critical towards medium level
- IoT vulnerabilities follow the same trend, but still far behind

Severity Analysis



IoT vs non-IoT (pp)

+20.3 UI: None
No user interaction needed: autonomous, remotely triggerable

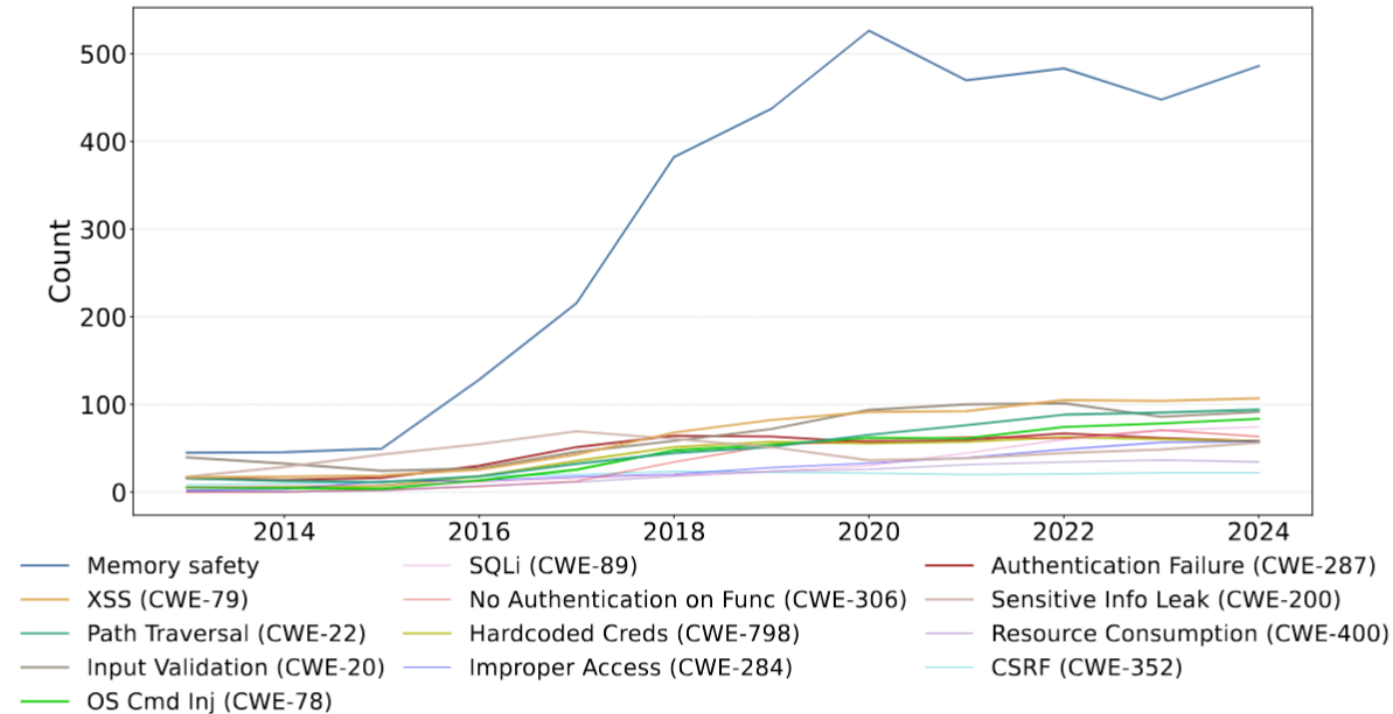
+11.9 PR: None
No privileges needed: missing or single-role auth

+11 to 13 C / I / A: High
Few internal boundaries: one bug, whole device

IoT vulnerabilities: lower-effort (no user interaction, no privilege), higher impact -> higher severity score

209 IoT CVEs in VulnCheck KEV

Weakness Family Analysis – CWE comparison



Memory safety issues: OOB write (CWE-787), OOB read (CWE-125), Stack-based buffer overflow (CWE-121), Use after free (CWE-416), Integer overflow (CWE-190), NULL dereference (CWE-476), Buffer copy without checking size of input (CWE-120), Memory-bound (CWE-119)

IoT

1. Memory safety

C language, poor memory protection in firmware

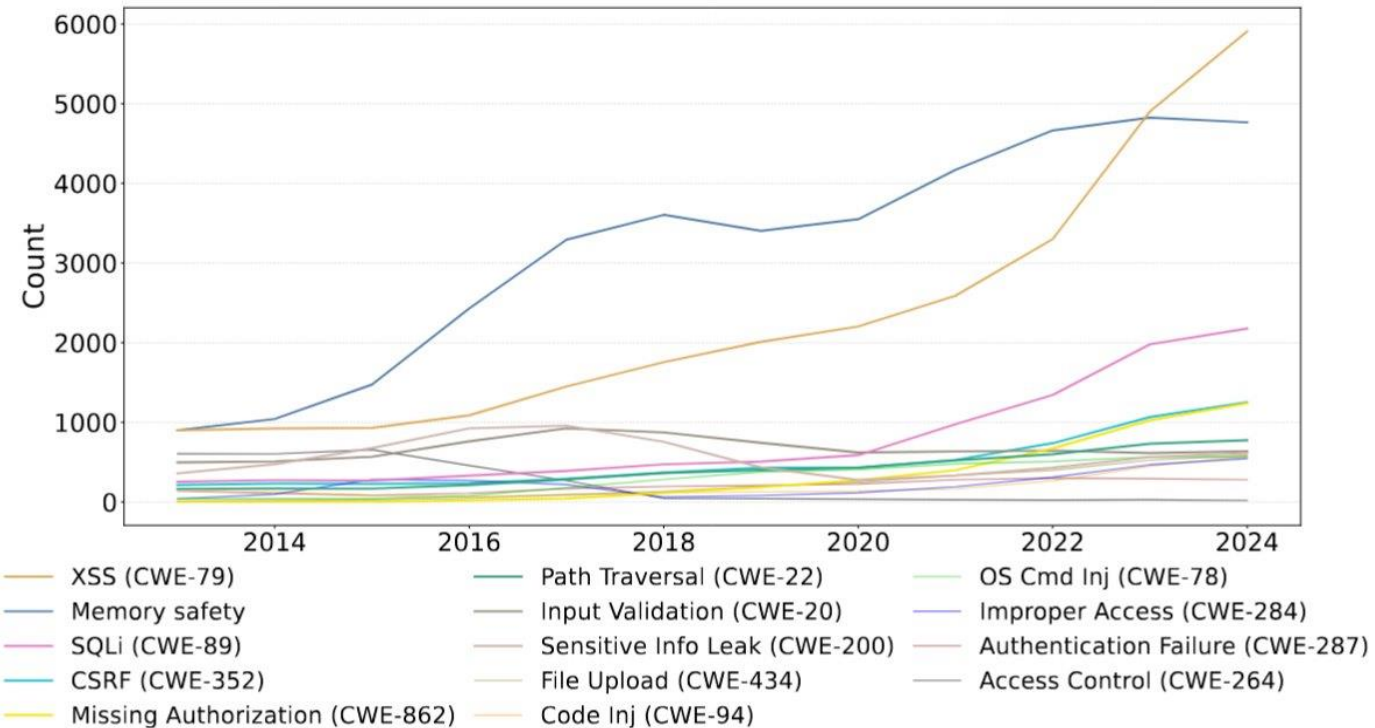
2. Web-centric weaknesses increasing in recent years (Input Validation, XSS, Path Traversal, SQLi, CSRF)

Growing use of web-based interfaces in IoT devices to provide user interaction and remote management

3. Authentication issue (#9 improper authentication, #7 no authentication on critical functions, and improper access control).

Resource constraints and neglecting security practices

Weakness Family Analysis – CWE comparison



Non-IoT

1. Web-centric weaknesses (XSS, SQLi, CSRF and Path Traversal,)

The ubiquity of web applications and the impact of large-scale automated discovery

2. Memory safety

3. Authorization issue

Multi-tenant architectures and access control mechanisms

Actionable Recommendations

Kill the low hanging-fruit vulnerability

- Hard-coded credentials
- Generate device-specific credentials during manufacturing.
- Enforce mandatory credential change at first setup.
- Provide secure physical reset mechanism.

Eliminate memory-safety issues

- Adopt memory-safe languages: Rust, Ada, MicroPython.
- Case study: Android → 76% memory bugs in 2019 → 24% in 2024.

Prevent web-based vulnerabilities

- Block web management interfaces from WAN access.
- Firewall rules for inbound traffic.
- Use cloud-based remote management with strong authentication.

Legislation and enforcement

- EU Cyber Resilience Act (CRA), adopted Dec 2024, full force 2027.
- Mandates security-by-design at every lifecycle stage.
- Radio Equipment Directive (RED) for wireless IoT devices.

Limitations and Future Work

- Borderline technologies
 - Future: Multi-label classification + post analysis
- Data source limitations
 - Rely solely on CVE description + CPE metadata, which can be incomplete.
 - Future: merge security advisories & vendor bulletins, or references for richer context

Conclusion

- Distinguishing IoT vulnerabilities requires a unified architectural abstraction that covers all contributing components.
- Using LLMs and the four-layer IoT taxonomy, we could overcome the limitations of previous works (scalability, high false positives).
- 15,066 IoT CVEs (8,391 new) that could be used for further research.
- IoT vs Non-IoT characterization: IoT = higher severity, lower attacker effort, memory-safety + growing web weaknesses

Thanks for your attention!

Questions?

Find the code and
dataset here!

